Northwind Labs IT and Information Security Policy

1. Purpose and Scope

This policy applies to all employees, contractors and interns who access Northwind systems, whether from the office, from home, or while travelling.

The Security team owns this policy and reviews it every 12 months. Questions can be sent to security@northwind.example.

2. Passwords and Authentication

Passwords must be at least 14 characters long. Passphrases made of several unrelated words are encouraged.

Passwords for company accounts must not be reused on any other website. Employees must store passwords in the company-approved password manager, 1Password.

Multi-factor authentication (MFA) is mandatory on email, the VPN, GitHub and all cloud consoles. Hardware security keys are required for anyone with production access.

Passwords do not expire on a fixed schedule. They must be changed immediately if there is any sign that they have been exposed.

3. Devices

Company laptops are encrypted with full-disk encryption and must lock automatically after 5 minutes of inactivity.

Operating system security updates must be installed within 7 days of release. Laptops that stay unpatched for more than 14 days lose access to the VPN until they are updated.

Personal devices may be used only for email and chat, and only after enrolling them in the company mobile device management (MDM) system.

4. Network Access

The company VPN, WireGuard-based NorthGate, must be used when accessing internal systems from outside the office.

Public Wi-Fi may be used only with the VPN switched on. Connecting to internal systems over public Wi-Fi without the VPN is a policy violation.

5. Data Classification

Company data falls into four classes: Public, Internal, Confidential and Restricted.

Restricted data, which includes customer personal data and payment information, must never be copied to personal devices, USB drives or personal cloud storage.

Confidential and Restricted data must only be shared through the company Google Drive with link sharing turned off.

6. Incident Reporting

Any suspected security incident, such as a phishing email that was clicked, a lost laptop or a leaked credential, must be reported to the Security team within 1 hour of discovery.

Incidents are reported in the #sec-incidents Slack channel or by calling the security hotline at extension 4040.

Employees will not be penalised for reporting an incident they caused by mistake. Hiding an incident is treated as a serious violation.

A lost or stolen laptop is wiped remotely by the IT team within 4 hours of the report.